Contents

1 Vulnerability Assessment Report **1**
1.1 1. Executive Summary . . . 1
1.2 2. Scope . . . 1
1.3 3. Assessment Results . . . 1
1.4 4. Vulnerability Register . . . 1
1.5 5. Remaining Validation . . . 2
1.6 6. Conclusion . . . 2
1.7 7. Version And Approval Record . . . 2

1 Vulnerability Assessment Report

Assessment date: 4-5 October 2026 **System:** Vitora HMIS **Environment:** Production pre-launch validation **Tools:** OWASP ZAP 2.17.0 and pytest/Django authorization regression suites **Assessor:** Nexora Consulting Ltd Engineering and Security Team

1.1 1. Executive Summary

Nexora Consulting Ltd performed a scoped vulnerability assessment of the Vitora HMIS production web application and API. The assessment used Context-scoped OWASP ZAP discovery/DAST, production response validation, and targeted automated authorization tests.

No High-risk vulnerability was identified in the scoped reports. The application and API were tested under a controlled pre-launch scope without live customer or patient data. Targeted tenant, RBAC, sensitive-access, and admin-security suites completed with 175 passing tests.

1.2 2. Scope

`https://app.vitora.digital`
`https://api.vitora.digital`

Third-party analytics, telemetry, marketing, and browser-support origins were excluded from final interpretation.

1.3 3. Assessment Results

Evidence	Result
Scoped production web ZAP report	0 High, 3 Medium, 1 Low, 7 Informational findings before final CSP hardening
Scoped production API ZAP report	0 High, 1 Medium, 2 Low, 5 Informational findings; API site summary contain
Multitenancy/organization PII/analytics tests	84 passed
Sensitive-access/RBAC/admin tests	91 passed
Production auth smoke test	Authenticated protected request returned 200; unauthenticated protected reque

\newpage

1.4 4. Vulnerability Register

ID	Vulnerability or observation	Description and security impact
VA-2026-10-01	CSP image source permitted all HTTPS origins	A broad image-source directive could perm
VA-2026-10-02	CSP allowed inline styles	Inline-style allowance could weaken policy
VA-2026-10-03	CSP absent on invalid `GET /_next` HTML 404	A framework error response without CSP
VA-2026-10-04	HTTP delivery and framework disclosure	Unencrypted delivery or technology disclos
VA-2026-10-05	Login response caching	Cached authentication responses could be
VA-2026-10-06	Private IP strings in static JavaScript bundle	Scanner identified private-address strings i
VA-2026-10-07	Scanner-generated `password=ZAP` URL	OWASP ZAP generated this URL while te

ID	Vulnerability or observation	Description and security impact
VA-2026-10-08	PWA state and Sentry replay session identifier in browser storage	Browser storage contained PWA state and
VA-2026-10-09	Minimal redirect Content-Type	A bodyless redirect returned a minimal co

Relevant remediation commits: `7f03fc922`, `1de5e1bb6`, and `c85bd7c9a`.

1.5 5. Remaining Validation

Manual cross-organization, cross-facility, sensitive-patient, and non-admin administrative-route validation has been completed. Before the first live facility onboarding, retain the tester, date, synthetic tenant/record type, expected/actual result, sensitive-access audit evidence where applicable, and reviewer approval for each manual smoke check. These controls address deployment/configuration drift and complement the existing automated regression evidence.

1.6 6. Conclusion

The assessment supports conditional pre-launch readiness. It is not an independent third-party penetration-test certificate and does not guarantee absence of vulnerabilities. The report must be reviewed alongside the penetration testing report, access-control policy, backup/recovery evidence, DPIA, and operational approval records.

\newpage

1.7 7. Version And Approval Record

Item	Record
Report version	1.1
Assessment completed	5 October 2026
Report reviewed	15 October 2026
Next assessment due	5 October 2027, or after a material security, infrastructure, or application change

Approval role	Name	Signature or approved electronic equivalent	Date
Assessment lead			
Security Lead			
Data Protection Officer / Compliance Lead			
Designated facility representative			